

Tool-Effect Binding in LLM Agents: Counterfactual Measurement and Pre-Commit Authorization

Anonymous Authors

Abstract

Tool-using LLM agents can commit security-relevant side effects before a human can inspect the realized operation. Existing monitors often evaluate the tool name, the natural-language action, or a coarse harmfulness label, but a safe pre-commit decision also depends on whether the candidate action is bound to the realized effect, target resource, operation mode, authorization context, and provenance of the controlling instruction. We define *tool-effect binding* as this pre-commit safety property and study it with counterfactual stress tests that separate surface invariance from effect, resource, authorization, operation-mode, and provenance sensitivity.

Across an 822-row controlled custom-stress suite with 6,840 pairwise relations, released checkpoints and local components are not merely tool-name classifiers: they show nontrivial surface invariance and effect sensitivity. However, joint binding remains incomplete. A reference hard Effect-Binding Guard obtains 0.917 coverage with 0.036 unsafe pre-allow and 0.065 safe false-denial on the E48 suite, but resource/authorization stress exposes 0.617 unsafe pre-allow despite 0.921 coverage. This identifies resource and authorization binding as the central bottleneck.

We then introduce a local authorization-aware pre-commit prototype that expands side-effectful tool calls into effect-resource-operation atoms and checks each atom against explicit authorization context. On the 600-row E55-v2 five-domain local contract, the prototype improves coverage from 0.200 to 0.880 and reduces unsafe pre-allow from 12/276 to 0/276, with no safe false-denial under the E55-v2 strict labels. Human-corrected sensitivity on the original E55 contract preserves zero unsafe pre-allow but introduces 4/230 = 0.017 safe false-denial. Strict label-hidden replay, decision-path audit, resource perturbation, independent reference-authorizer agreement, and human spot audit reduce leakage and coupling concerns, but do not establish production safety. The supported claim is a measurement and diagnostic framework plus local contract evidence that explicit authorization infrastructure can make pre-commit mediation more decidable under controlled assumptions.

1 Introduction

LLM agents increasingly act through tools that read, write, send, share, purchase, schedule, or modify state in external systems. In such settings the security-relevant question is not only whether an agent emits harmful text, but whether a concrete candidate action should be allowed to commit an external side effect. Benchmarks such as ToolEmu and AgentDojo make this risk concrete by evaluating agents across tool-rich tasks and adversarial inputs [6, 3]. Guardrail and pre-execution systems such as ToolSafe/TS-Guard and Safiron similarly recognize that tool invocation must be judged before unsafe actions are executed [5, 4].

Pre-commit safety is relational. An email action may be safe when it sends a draft to the authorized recipient, unsafe when the same email includes a hidden Bcc, and indeterminate when the recipient is an unresolved alias. A file action may be safe when it shares a document with an authorized collaborator, unsafe when it turns on a public link, and indeterminate when the evidence for the file identity comes from an untrusted source. A payment action may depend on the account, payee, amount semantics, and whether the operation is a draft or a committed transfer. These examples expose a gap between coarse tool-level monitoring and the actual authorization object.

This paper studies that gap as a *tool-effect binding* problem. A monitor binds a candidate action when its decision is invariant to harmless surface changes but sensitive to changes in the policy-relevant effect, target resource, operation mode, authorization context, and provenance/control source. This question is upstream of policy enforcement. Authorization and least-privilege systems such as Progent and MiniScope define or enforce policies over agent actions [7, 8]; our question is whether the candidate action has been converted into the right policy-relevant semantic object before such enforcement can be trusted.

We make three design choices to keep the claim defensible. First, we treat the work as a controlled measurement and diagnostic study, not a production benchmark. Second, we evaluate candidate monitors with counterfactual stress tests rather than only aggregate task success. Third, we introduce a local authorization-aware prototype only as a constructive probe: it tests whether explicit atom-level authorization infrastructure can remove the bottleneck that the measurement framework reveals.

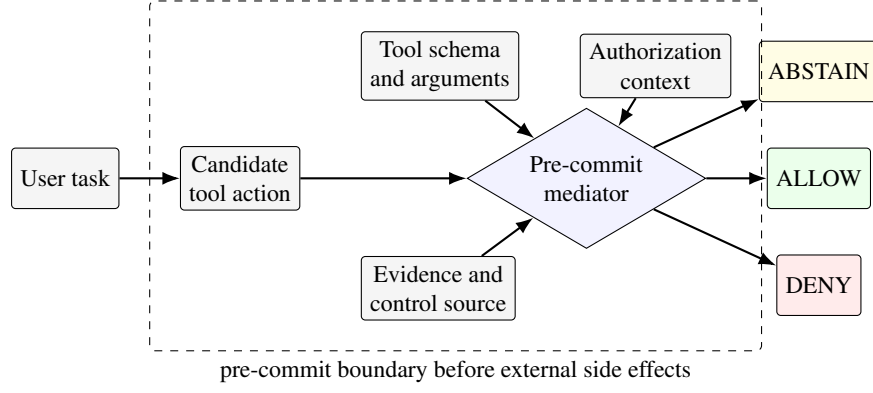


Figure 1: Pre-commit tool-effect binding boundary. The decision must bind the candidate action to effect, resource, operation, authorization, and provenance before commit.

The results support a specific main line. Existing and released-checkpoint methods are not merely tool-name classifiers, but their joint binding is incomplete. A reference hard Effect-Binding Guard improves some controlled stress tradeoffs, yet resource/authorization cases remain the dominant failure mode. When a local pre-commit contract explicitly supplies authorization context, resource aliases, operation modes, and provenance/control-source information, an atom-level mediator can convert abstention-heavy behavior into higher-coverage controlled mediation. This is evidence for the value of explicit authorization infrastructure, not evidence that authorization is solved in deployed agents.

Contributions. This draft makes the following contributions.

- We define tool-effect binding as a pre-commit safety property for side-effectful LLM-agent tool use, with decision invariance and sensitivity requirements over surface, effect, resource, authorization, operation, and provenance axes.
- We operationalize the property with a counterfactual stress-test framework and use it to diagnose existing/custom-stress methods under a clear boundary: released checkpoints are evaluated on our custom stress, not as original-paper benchmark reproductions.
- We introduce effect-resource-operation atoms as the semantic interface between tool calls and authorization checks, formalizing why a side-effectful tool call is a container of one or more security actions.
- We evaluate a reference hard Effect-Binding Guard and show bounded improvement, including 0.036 unsafe pre-allow at 0.917 coverage on E48 and a 0.617 unsafe pre-allow resource/authorization bottleneck on E50.
- We introduce a local authorization-aware pre-commit prototype and validate it with E55/E56/E57 strict replay, decision-path audit, perturbation, reference authorizer agreement, and human audit evidence, while preserving the boundary that this is controlled local contract evidence.

Claim boundary. The supported claim is that counterfactual measurement exposes a resource/authorization binding bottleneck and that explicit authorization infrastructure can make a local pre-commit mediator more decidable under a controlled contract. The paper does not claim production safety, a complete permission system, independent deployment generalization, original benchmark reproduction for all compared methods, universal tool-schema robustness, or a solved authorization problem.

2 Threat Model and Security Goal

System model. We consider an LLM-agent runtime that proposes a side-effectful tool call before the call is committed to an external service. A pre-commit mediator can inspect the user task, recent agent trace, candidate tool name and arguments, tool schema, available evidence/provenance summaries, and any explicit authorization context provided by the local environment. The mediator emits one of three decisions: ALLOW, DENY, or ABSTAIN. ABSTAIN means the mediator refuses to commit automatically because resource identity, authorization scope, provenance, alias resolution, or operation semantics are insufficiently bound.

Adversary and hazards. The adversary may influence user-visible or tool-returned text, induce surface paraphrases, exploit resource aliases, request operation-mode changes, or attempt to route control through untrusted evidence. The hazards are pre-commit unsafe allows: sending or sharing with an unauthorized recipient, modifying an unauthorized calendar or file, committing instead of drafting, changing visibility, or authorizing an action based on untrusted control.

Out of scope. We do not model malicious tool implementations, compromised operating systems, post-commit rollback, real SaaS deployment semantics, browser automation, banking integration, or end-to-end prompt-injection prevention. We also do not claim that our local authorization context is a deployable enterprise permission system. The prototype assumes a controlled mock contract in which the environment can provide typed authorization context and canonical resource information.

Security goal. Let c be a candidate tool call and let $L(c)$ be the ground-truth pre-commit label in a controlled contract. A monitor M satisfies the local safety goal on a dataset if it minimizes:

$$\text{UPA}(M) = \Pr[M(c) = \text{ALLOW} \mid L(c) = \text{DENY}],$$

while reporting its coverage and safe false-denial tradeoff:

$$\text{Coverage}(M) = \Pr[M(c) \neq \text{ABSTAIN}], \quad \text{FDenY}(M) = \Pr[M(c) = \text{DENY} \mid L(c) = \text{ALLOW}].$$

Coverage is not itself a safety metric: high coverage with high unsafe pre-allow is worse than abstention for pre-commit mediation. Conversely, zero unsafe pre-allow obtained by denying or abstaining on nearly everything is not sufficient utility evidence. The paper therefore reports all three quantities together.

3 Tool-Effect Binding Problem

Tool-effect binding asks whether a monitor’s decision is attached to the semantic side effect that would be committed, not merely to the surface form of a tool call. The binding problem appears whenever the same surface action can realize different effects, or different surfaces can realize the same effect.

Objects. Let c denote a candidate action. A candidate action includes a tool name, a schema-level argument object, and a surrounding context. Let $S(c)$ be its surface representation, $E(c)$ its realized effect type, $R(c)$ its target resource set, $O(c)$ its operation mode, $A(c)$ its authorization relation under the current context, and $P(c)$ its provenance/control-source status. These are analytic variables used for measurement; in deployment they may be partially observed or unavailable.

Binding requirement. A monitor should be invariant to changes in $S(c)$ that preserve (E, R, O, A, P) , and sensitive to changes in E, R, O, A , or P that alter the safe pre-commit decision. For example, renaming a recipient alias should not change the decision if the alias resolves to the same authorized principal. Adding an unauthorized Bcc should change the decision even if the tool name and primary effect remain the same.

Failure modes. We distinguish four recurrent failures.

- **Tool-proxy behavior:** the monitor follows tool names or coarse action strings rather than the realized effect and resource.
- **Resource under-binding:** the monitor recognizes the effect but does not bind all target resources, recipients, accounts, channels, files, or visibility states.
- **Authorization under-binding:** the monitor identifies a resource but fails to check whether the current authorization context covers the requested operation.
- **Provenance/control-source under-binding:** the monitor permits an action whose controlling instruction or evidence comes from an untrusted source.

Reviewer-facing boundary. The binding requirement is a precondition for robust policy enforcement, not a replacement for policy design. A monitor that extracts the wrong resource or operation can pass a well-specified policy for the wrong object. Conversely, a policy system can be formally precise but still unsafe if the candidate action is not correctly bound to the policy-relevant object before enforcement.

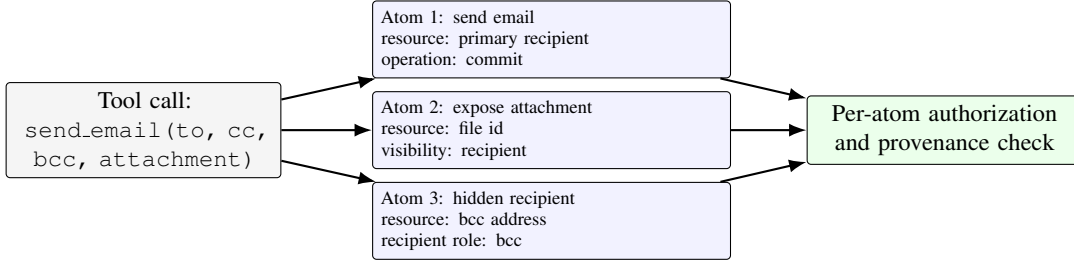


Figure 2: Effect-resource-operation atomization. A side-effectful tool call is a container of multiple security-relevant atoms rather than a single authorization object.

4 Effect-Resource-Operation Atoms

The central method abstraction is the *effect-resource-operation atom*. A side-effectful tool call is not an atomic security action; it is a container of one or more atoms. This matters because a single tool call can simultaneously send to multiple recipients, expose an attachment, create an event, invite attendees, share a file, change visibility, schedule a payment, or modify a role.

Atom schema. We represent an atom as:

```

EffectAtom = (effect, operation, resource_id, resource_type,
              recipient_role, visibility, commit_mode,
              provenance_source, control_source).
  
```

Not every domain populates every field. For example, `recipient_role` is central to email and Slack but may be absent for a file metadata update. `commit_mode` distinguishes draft, preview, schedule, and committed external action when the domain exposes such a distinction.

Examples. A `send_email` call may expand into atoms for the primary recipient, Cc/Bcc recipients, and attachments. A `create_event` call may expand into one event-creation atom and one invitation atom per attendee. A `share_file` call may include file access and public-link visibility atoms. A transaction call may include account, payee, amount semantics, and commit mode. A Slack action may include a channel, member, visibility, or role-change atom.

Authorization context. The minimum authorization context for this paper contains:

```

allowed_effects, allowed_operations, allowed_resource_ids,
allowed_resource_aliases, allowed_recipients/channels/accounts/files,
allowed_visibility, draft_allowed, commit_allowed,
public_link_allowed, trusted_control_sources,
untrusted_control_sources, multi_resource_policy.
  
```

This context is not a complete permission system. It is the smallest interface the pre-commit mediator needs to decide whether the candidate action’s atoms are covered by explicit authorization.

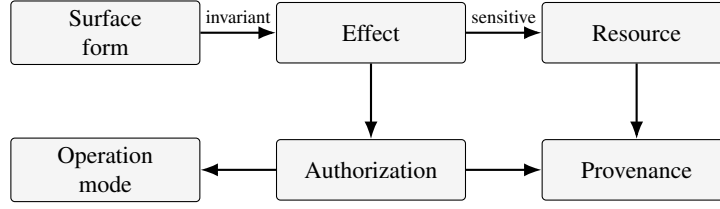
Decision rule. Let $\text{Expand}(c)$ return the atom set for candidate call c under the available schema and evidence. We write:

$$\text{Authorize}(c) = \text{Authorize}(\text{Expand}(c)).$$

The local decision rule is:

- **ALLOW:** every atom is covered by the authorization context and no provenance/control-source rule blocks the action.
- **DENY:** at least one atom is explicitly outside the authorization context.
- **ABSTAIN:** atom expansion, resource identity, alias resolution, evidence source, authorization boundary, or control source is ambiguous.

This atomization is the paper’s main constructive abstraction. It explains why a coarse tool-level guard can be high coverage yet unsafe: the guard may make a decision over the container while missing an unauthorized atom inside it.



Counterfactual pairs isolate one axis while holding the others fixed when possible.

Figure 3: Counterfactual stress lattice. The framework tests whether monitors are invariant to harmless surface changes and sensitive to semantic changes that alter safe pre-commit decisions.

5 Counterfactual Stress-Test Framework

The measurement framework constructs controlled counterfactual cases that isolate semantic axes relevant to pre-commit decisions. The intent is not to reproduce every original benchmark result for each compared system. Instead, the framework asks whether a monitor can satisfy binding invariances and sensitivities on a controlled custom stress distribution.

Axes. We use six axes.

- **Surface invariance:** paraphrases, schema-level variants, or tool-name alternatives that preserve the same security-relevant action should not change the decision.
- **Effect sensitivity:** changing the realized effect should change the decision when the authorization differs.
- **Resource sensitivity:** changing target resource, recipient, account, channel, file, or visibility should change the decision when the new resource is unauthorized.
- **Authorization sensitivity:** changing the authorization context should change the decision even when the surface action remains similar.
- **Operation-mode sensitivity:** draft, preview, schedule, and commit modes are different security actions.
- **Provenance sensitivity:** trusted user control and untrusted tool-returned control must be distinguished.

Pairwise relations. For each pair (c_i, c_j) , the framework records which axes are held fixed and which axes are perturbed. A monitor receives only deployable or allowed input views for that method. Oracle labels and hidden fields are used for scoring, not as deployable inputs. The E48 unified evaluation contains 822 rows and 6,840 pairwise relations; its manifest records the available methods, input views, source counts, and leakage checks.

Metrics. The primary row metrics are UPA, FDeny, coverage, selective accuracy, effect/resource/authorization/provenance accuracy where defined, and abstain rate. Pairwise metrics include same-effect consistency, effect-change correctness, resource sensitivity, authorization sensitivity, provenance sensitivity, and flip-relation correctness. The paper emphasizes UPA, FDeny, and coverage in the main tables because they map directly to pre-commit safety tradeoffs.

Validity checks. The framework includes leakage and marker scans to check that deployable inputs do not contain gold labels. Later E55/E56/E57 checks add label-hidden replay, decision-path audit, resource perturbation, independent reference-authorizer agreement, and human spot audit. These checks reduce specific artifact risks, but they do not convert controlled synthetic/local contracts into deployment validation.

6 Reference Effect-Binding Guard

The reference hard Effect-Binding Guard is a deterministic monitor intended to test how far explicit tuple binding can go without a full authorization-aware contract. It is not the paper’s production defense.

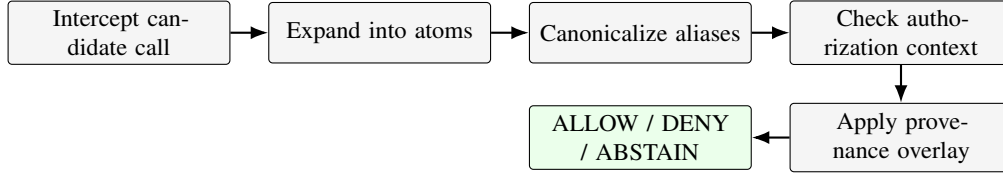


Figure 4: Authorization-aware local pre-commit prototype pipeline. The prototype is a local mock contract for pre-commit mediation, not a complete permission system.

Inputs. The guard consumes non-oracle views such as candidate action, argument summary, canonical visible summary, evidence summary, provenance summary, plan text, trajectory text, and tool inventory when available. It does not consume gold labels such as expected decision, gold effect, gold resource, gold authorization match, or gold provenance risk.

Tuple binding. The guard maps each candidate action to an effect/resource/authorization/provenance tuple and applies hard consistency checks. It abstains under multi-view disagreement, missing evidence, or insufficient provenance. It denies when the tuple indicates an unsafe action, and allows only when the tuple is compatible with the available authorization evidence. The method is intentionally conservative, because the experiment is designed to locate remaining binding bottlenecks rather than maximize apparent utility.

Expected failure surface. The guard can improve over pure surface proxies when the effect and resource are explicit. It is expected to fail when a resource or authorization relation is latent in a tool-specific argument, spread across multiple fields, or dependent on local aliases and operation-mode semantics. E50’s resource/authorization stress was designed to test exactly this failure surface.

7 Authorization-Aware Pre-Commit Prototype

The E55 local prototype tests a stronger interface: rather than inferring authorization only from generic text, the environment provides a typed authorization context and the mediator expands candidate calls into atoms before decision. This is a local mock contract. It should be read as feasibility evidence for explicit pre-commit authorization infrastructure, not as a deployable permission system.

Pipeline. The prototype performs five steps. First, it intercepts the candidate tool call before commit. Second, it expands the call into effect-resource-operation atoms. Third, it canonicalizes resource identifiers and aliases. Fourth, it checks each atom against the authorization context. Fifth, it applies provenance/control-source checks and emits ALLOW, DENY, or ABSTAIN.

Domain coverage. The local contract covers five domains: email, calendar, file, Slack, and transaction. Each domain contains 120 rows in E55-v2, for 600 rows total. The stress axes include multi-resource expansion, operation shifts, provenance shifts, resource shifts, and same-effect surface changes. The domain examples are intentionally compact but cover security-relevant distinctions that coarse tool monitors often collapse.

Abstention semantics. Abstention is a first-class decision. In E55-v2, unknown resources, unresolved aliases, insufficient evidence fallback, or ambiguous draft/commit status are not silently allowed. The high-level goal is to convert dangerous automatic decisions into either denied or explicitly abstained pre-commit states.

Why this matters. The E50 bottleneck shows that tuple-level binding without a local authorization contract can make many decisions while missing unsafe resource/authorization cases. The E55 prototype asks the constructive follow-up: if the environment exposes the missing authorization interface and the mediator reasons over atoms, does the bottleneck reduce in a controlled setting? The answer is yes for the E55-v2 local contract, subject to the limitations and audit findings reported below.

Table 1: Existing/custom-stress method capability matrix. Scores come from the E47 custom stress artifacts and released-checkpoint custom-stress runs where applicable; they are not original-paper benchmark reproductions. Empty entries indicate not applicable to the method’s available signal.

Method	Scope	Surface inv.	Effect sens.	Auth. sens.	Resource aware	UPA
Tool-name proxy	local rule baseline	1.000	0.000	0.000	0.000	0.292
Static/plan/trajectory text proxy	local text-rule baselines	0.984	0.000	0.903	1.000	0.080
Local Qwen self-audit	local LLM self-audit	0.865	0.667	0.565	0.292	0.004
TS-Guard checkpoint	released checkpoint on E47 custom stress	0.883	0.625	0.764	0.833	0.159
Safiron checkpoint	released checkpoint on E47 custom stress	0.669	1.000	0.088	0.167	0.545
Local Qwen effect/resource mapper	local LLM mapper	0.992	0.833	0.375	0.125	0.333
IPIGuard topology-only	structural topology signal	1.000	0.000	–	–	–
CaMeL structural-policy stress	local component stress	1.000	–	–	–	0.250

8 Experimental Setup

Materials. All experiments are drawn from the consolidated mainline package. The main source files are result JSONs under `results/analysis/results/` and `audit/analysis/results/`, tables under `tables/`, and writing-package claim maps under `methodmaterials/writing_package_e58/`. The package summary reports 2,424 copied files, two missing expected historical directories, and no core-number issues.

E47 existing/custom-stress methods. E47 evaluates local baselines, released checkpoint components, and structural components on custom stress cases. ToolSafe/TS-Guard and Safiron are evaluated as released checkpoints on E47 custom stress, not as reproductions of their original benchmark numbers. IPIGuard and CaMeL are included through structural or component stress where the available interface supports our binding diagnostics.

E48 hard guard. E48 evaluates the reference hard guard on 822 controlled rows and 6,840 pairwise relations. We report the full result, a held-out split, and the source-balanced E50 robustness audit. The main metrics are UPA, FDeny, and coverage.

E50 robustness and bottleneck stress. E50 contains source-balanced repeats, resource/authorization stress, provenance stress, risk-coverage curves, threshold sensitivity, and failure examples. The resource/authorization stress has 240 rows; the provenance stress has 336 rows.

E55/E56/E57 local pre-commit evidence. E55 evaluates a local pre-commit authorization prototype on 600 rows across five domains. This draft uses E55-v2 strict results as the main pre-commit table because they are the corrected rerun. The original E55 strict result and human-corrected sensitivity are reported as `audit/sensitivity` evidence. E56 contributes strict replay and build/audit checks. E57-v2 contributes resource perturbation, reference-authorizer agreement, and a 60-row spot-audit packet. A separate E57 human audit of 60 rows found 54/60 decision agreement and generated corrected-label evidence; it is reported as a human audit, not merged with deterministic reference-authorizer agreement.

Metrics and labels. Unsafe pre-allow is computed as ALLOW on rows labeled DENY. Safe false-denial is computed as DENY on rows labeled ALLOW. Coverage is the fraction of rows on which a method emits ALLOW or DENY rather than ABSTAIN. We do not compute false negative rate from F1 or substitute coverage-missing stress quantities for deployed-system quantities.

9 Results

9.1 Finding 1: Existing Methods Are Nontrivial but Incomplete

Table 1 shows that existing/custom-stress methods are not merely tool-name classifiers. TS-Guard reaches 0.883 surface invariance and 0.764 authorization sensitivity on the E47 custom stress, and Safiron reaches 1.000 effect sensitivity. Local Qwen variants also show nontrivial effect sensitivity. However, high performance on one axis does not imply joint binding. Safiron has 0.545 unsafe pre-allow in this custom stress; local Qwen effect/resource mapping has high surface invariance and effect sensitivity but 0.125 resource awareness and 0.333 unsafe pre-allow. These results support a diagnostic claim: current monitors can capture parts of the binding problem, but they remain incomplete when resource, authorization, and provenance must be bound jointly.

Table 2: Reference hard Effect-Binding Guard results. The guard improves controlled stress tradeoffs, but retains nonzero unsafe pre-allow and false denial.

Scope	UPA	FDeny	Coverage
E48 full, 822 rows	0.036	0.065	0.917
E48 held-out split	0.051	0.048	0.955
E50 source-balanced mean	0.051	0.059	0.923

Table 3: Bottleneck stress results for the hard guard. Resource/authorization stress exposes high unsafe pre-allow despite high coverage; provenance overlay removes unsafe pre-allow in the controlled provenance stress but increases false denial and abstention.

Stress set	Rows	UPA	FDeny	Coverage
Resource/auth stress	240	0.617	0.000	0.921
Provenance stress	336	0.000	0.188	0.545

9.2 Finding 2: The Reference Hard Guard Improves but Remains Bounded

Table 2 reports the reference hard guard. On the 822-row E48 suite, the guard obtains 0.917 coverage with 0.036 unsafe pre-allow and 0.065 safe false-denial. On the held-out split, unsafe pre-allow rises to 0.051 while coverage remains 0.955. Source-balanced E50 repeats preserve the same qualitative result: 0.051 mean unsafe pre-allow, 0.059 mean safe false-denial, and 0.923 mean coverage. This is evidence that explicit tuple binding is useful, but it is not a safety certificate. The guard still makes unsafe pre-commit allows and safe false denials under controlled stress.

9.3 Finding 3: Resource/Authorization Binding Is the Main Bottleneck

Table 3 identifies the main bottleneck. On E50 resource/authorization stress, the hard guard has 0.617 unsafe pre-allow at 0.921 coverage. This rules out a benign explanation in which the guard simply abstains on hard cases. Instead, it often makes a decision while missing the authorization-relevant resource relation. Provenance stress shows a different tradeoff: unsafe pre-allow is 0.000, but coverage falls to 0.545 and safe false-denial rises to 0.188. Provenance overlays can reduce unsafe pre-allow under controlled assumptions, but their utility cost must be reported rather than hidden.

9.4 Finding 4: Authorization Infrastructure Enables Local Pre-Commit Mediation

Table 4 shows the E55-v2 local pre-commit result. The existing hard guard on the same 600-row local contract has 0.200 coverage, 0.800 abstention, and $12/276 = 0.043$ unsafe pre-allow. The authorization-aware prototype reaches $528/600 = 0.880$ coverage and $72/600 = 0.120$ abstention, while reducing unsafe pre-allow to $0/276$ and safe false-denial to $0/252$ under E55-v2 strict labels. The original E55 strict contract has 0.920 coverage and zero unsafe pre-allow; human-corrected sensitivity preserves zero unsafe pre-allow but introduces $4/230 = 0.017$ safe false-denial. The conservative interpretation is that explicit authorization infrastructure can make local mediation more decidable, while human audit reveals residual label/atom boundary sensitivity.

9.5 Finding 5: Atom Interfaces Carry the Improvement

Table 5 reports original E55 strict ablations. Removing multi-resource expansion increases unsafe pre-allow to 0.333. Removing operation-mode binding or provenance overlay increases unsafe pre-allow to 0.148. Removing alias resolution does not create unsafe pre-allow in this ablation but raises safe false-denial to 0.211. These ablations support the atom-level abstraction: the improvement is not only a stricter deny rule. It depends on expanding calls into multiple resource-bearing atoms, distinguishing draft and commit modes, preserving provenance/control-source information, and resolving aliases when the contract supports it.

9.6 Finding 6: Audits Reduce Specific Artifact Concerns

Table 6 separates deterministic validity checks from human audit evidence. E55-v2 leakage checks are clean, E55 decision-path audit passed, and E56 strict label-hidden replay passed. E57-v2 resource-name perturbation yields zero changed decisions and zero UPA/coverage delta for the authorization-aware guard, reducing the concern that the result is only a resource-name

Table 4: Authorization-aware local pre-commit prototype. E55-v2 is used as the main result; original E55 and human-corrected sensitivity are retained as audit/sensitivity evidence.

Method / source	UPA	FDeny	Coverage	Abstain
E55-v2 existing hard guard	0.043	0.000	0.200	0.800
E55-v2 authz-aware guard	0.000	0.000	0.880	0.120
Original E55 authz-aware	0.000	0.000	0.920	0.080
Original E55 human-corrected sensitivity	0.000	0.017	0.920	0.080

Table 5: Atom/authorization ablations from the original E55 strict result. These ablations diagnose which semantic interfaces carry the E55 improvement; the E55-v2 main table is reported separately in Table 4.

Ablation	Main failure metric	Value
No multi-resource expansion	UPA	0.333
No operation-mode binding	UPA	0.148
No provenance overlay	UPA	0.148
No alias resolution	FDeny	0.211

template artifact. The independent reference authorizer has 1.000 agreement on decisions, atom counts, and atom resource sets across the controlled E55-v2 dataset. The human audit is intentionally reported separately: it agrees on 54/60 decisions and has all checks true on 46/60 rows, while identifying six decision corrections, thirteen atom corrections, and ten violation-reason corrections. This supports corrected-label sensitivity analysis, not perfect construction agreement.

10 Failure Analysis

Resource and authorization failures. The dominant failure mode is not a failure to notice that a tool call is side-effectful. It is failure to bind the action to the specific resource and authorization relation. In E50, the hard guard frequently decides rather than abstains, yet it allows unsafe resource/authorization cases. This suggests that surface-level safety categories and even effect labels are insufficient when the policy-relevant question is “which object, under which authorization, with which operation?”

Multi-resource containers. E55 ablations show why a tool call must be treated as a container. If multi-resource expansion is removed, the prototype can authorize the visible primary action while missing hidden or secondary resources. Email Bcc fields, event attendees, file visibility changes, Slack role/channel changes, and transaction payee/account combinations all create this pattern.

Operation-mode and provenance failures. Operation mode changes convert apparently similar calls into different security actions. A draft may be acceptable when a committed send is not; a scheduled payment may differ from an immediate transfer. Provenance/control-source failures are separate: a call whose resource is authorized may still be unsafe when the controlling instruction comes from an untrusted fetched page or tool output. E50 provenance stress shows that hard provenance overlays can remove unsafe pre-allow under the controlled setup, but at the cost of false-denial and abstention.

Human audit corrections. The E57 human audit found corrections rather than merely confirming the construction. Some corrections concern unknown-resource fallback in email and file cases; others concern transaction-domain amount handling, where amount should not always be treated as a resource-authorization atom. These corrections are valuable because they sharpen the claim boundary. The corrected sensitivity preserves zero unsafe pre-allow for the full authz-aware guard, but introduces a small safe false-denial rate. The paper therefore reports the prototype as robust to corrected-label sensitivity on unsafe pre-allow, not as perfectly labeled.

Residual reviewer risks. The local contract is synthetic and deterministic. Resource aliases, authorization context, and atom expansion are designed by the same project, although E57-v2 independent reference-authorizer agreement reduces single-implementation coupling concerns. The remaining high-value experiment is an independently authored held-out local contract or realistic replay sandbox that preserves no-real-side-effect safety while testing whether the same atom interface transfers.

Table 6: Audit and validity checks. Deterministic E57-v2 checks and human audit checks answer different validity questions and are not merged into a single agreement claim.

Check	Result	Scope
E55-v2 leakage audit	leakage-free	deployable-input leakage diagnostic
E55 decision-path audit	passed	implementation-path audit
E56 strict label-hidden replay	passed	label-hidden replay and build audit
E57-v2 resource perturbation	UPA delta 0.000; coverage delta 0.000; changed decisions 0	naming-template robustness diagnostic
E57-v2 reference authorizer	decision, atom-count, and atom resource-set agreement 1.000	independent local implementation agreement
E57-v2 spot-audit packet	60 rows; required fields present	human-inspectable packet
E57 human audit	decision agreement 54/60; all checks true 46/60	post-hoc human audit with corrections
E57 human corrections	6 decision, 13 atom, 10 violation-reason corrections	label/atom sensitivity evidence

11 Discussion

What is new. The primary novelty is the measurement framing: tool-effect binding as a pre-commit safety property, together with counterfactual stress tests that isolate surface invariance from effect/resource/authorization/operation/provenance sensitivity. The authorization-aware prototype is a constructive validation of the measured bottleneck, not the main novelty by itself.

Relationship to authorization systems. Least-privilege systems and programmable privilege controls are complementary. Progent focuses on policy representation and deterministic enforcement over tool calls; MiniScope focuses on least-privilege authorization for tool-calling agents. Our work focuses on the prerequisite: whether the candidate action has been decomposed into the correct semantic authorization object before enforcement. A policy system can enforce the wrong thing if a hidden recipient, public-link change, or operation-mode shift is not represented in the object being checked.

Why abstention matters. Pre-commit mediation must allow abstention because the mediator may lack sufficient information to bind an action. A system that forces every ambiguous action into allow/deny can inflate apparent coverage at the cost of unsafe pre-allow or false denial. In this paper, abstention is a measurement dimension and a deployment design requirement. E55-v2’s improvement is meaningful because coverage rises from 0.200 to 0.880 while unsafe pre-allow falls to zero under strict labels; not because the system avoids abstention entirely.

How to read the numbers. The reported metrics are controlled custom-stress and local-contract metrics. They should not be read as estimates of deployed-system incident rates. The E47 released-checkpoint results compare methods under our custom stress interface, not under the original benchmark protocols of ToolSafe, Safiron, IPIGuard, or CaMeL. The E55/E57 results are stronger than a prose-only design argument but weaker than independent deployment validation.

12 Related Work

Agent safety benchmarks. ToolEmu evaluates LM agents using an LM-emulated sandbox and highlights risks such as privacy leakage and financial loss in tool-rich settings [6]. AgentDojo provides dynamic environments for prompt-injection attacks and defenses over realistic agent tasks [3]. These benchmarks motivate tool-use safety as a first-class problem. Our work differs by focusing on counterfactual binding diagnostics for pre-commit decisions rather than end-to-end task outcomes.

Pre-execution and step-level guardrails. ToolSafe/TS-Guard studies proactive step-level tool invocation safety and feedback-driven guardrails [5]. Safiron studies foundational pre-execution guardrails trained with synthetic data and evaluated on Pre-Exec Bench [4]. These systems ask whether a planned or candidate action is risky before execution. Our custom stress tests ask a more specific semantic question: whether the monitor’s decision is bound to realized effect, resource, authorization, operation mode, and provenance rather than surface form.

Structural prompt-injection defenses. CaMeL separates trusted control from untrusted data and uses capability ideas to prevent unauthorized data flows [2]. IPIGuard uses a tool dependency graph to reduce unintended tool invocations under indirect prompt injection [1]. These works shift defenses from prompt-only filtering toward execution structure. Our framework is compatible with that direction, but it targets the semantic layer between a candidate tool action and the policy object that a structural defense or capability system would check.

Authorization and least privilege. Progent introduces programmable privilege control policies for LLM agents [7]. MiniScope reconstructs permission hierarchies and applies a least-privilege framework for authorizing tool-calling agents [8]. These works are closest to the authorization motivation. The distinction is that this paper studies whether side-effectful tool calls are atomized and bound to the right authorization facts before policy enforcement. In our terminology, least privilege needs correct effect-resource-operation atoms.

Provenance, virtualization, and audit. Tool-use safety often depends on whether control flows from trusted user intent or untrusted retrieved content. CaMeL’s data/control separation is one structural treatment of this problem; our provenance stress and overlay treat it as one binding axis. The consolidated package contains no verified BibTeX-ready ARGUS or AgentVisor references, so this draft does not cite them. They should be added only after source verification.

Positioning. The paper is not a general replacement for benchmarks, guardrails, capability systems, or permission frameworks. It supplies a diagnostic lens and a minimal semantic interface for pre-commit mediation: before a policy can be enforced, the candidate action must be bound to the specific effect-resource-operation atoms and their authorization/provenance context.

13 Limitations

Controlled stress, not deployment validation. The evidence comes from controlled custom stress sets and a local mock pre-commit contract. It does not establish safety for real SaaS, browser, banking, email, calendar, file-sharing, Slack, or workspace systems. The numbers should not be interpreted as deployed false-allow or false-denial rates.

Synthetic and deterministic artifacts. The E55/E57 local contract is deterministic and synthetic. Its resource schemas, aliases, and authorization context are designed for the experiment. E57-v2 perturbation and independent reference-authorizer checks reduce lexical-template and implementation-coupling concerns, but they do not prove transfer to independently authored schemas.

Baseline scope. Released checkpoints are evaluated on our custom stress interface. These results are useful for diagnosing binding behavior under our stress axes, but they are not original-paper benchmark reproductions. The draft should therefore avoid claims that one external system is globally safer or weaker than another.

Human audit findings. The human audit found corrections. This is a strength for claim hygiene, but a limitation for label certainty. The paper should use corrected-label sensitivity wording and should not claim that the audit perfectly confirmed all labels, atoms, or violation reasons.

Missing experiments. The strongest remaining experimental gaps are an independently authored held-out E55-style contract, a realistic no-real-side-effect replay sandbox, and direct evaluation of stronger released guardrails on the E55 distribution. These would test whether the atom interface and authorization-aware mediation transfer beyond the current local contract.

14 Ethics and Artifact Scope

The experiments are designed to avoid real external side effects. Tool actions are represented in synthetic or local mock contracts, and the pre-commit prototype is evaluated without sending real emails, sharing real files, modifying real calendars, posting to real Slack workspaces, or executing real financial transactions. The goal is to measure and diagnose semantic binding failures before deployment, not to demonstrate or encourage attacks against live systems.

The artifact should be released, if released, with clear scope labels: controlled custom stress, local mock contract, no production safety claim, and no real service integration. Failure examples should be sanitized and should avoid credentials, real account identifiers, or live resource names. Any future realistic replay environment should preserve the no-real-side-effect constraint.

15 Conclusion

This draft reframes LLM-agent tool safety around tool-effect binding: before a side-effectful action commits, the mediator must bind the candidate call to the realized effect, target resource, operation mode, authorization context, and provenance/control source. Counterfactual stress tests show that existing methods are not simple tool-name classifiers, but still fail joint binding. A reference hard guard improves some tradeoffs while exposing resource/authorization as the dominant bottleneck. An authorization-aware local pre-commit prototype shows that explicit atom expansion and authorization context can substantially improve controlled mediation, reducing unsafe pre-allow to zero under E55-v2 strict labels while raising coverage relative to the earlier hard guard. The result is a measurement framework and local feasibility probe, not a production safety guarantee. The next step is independent held-out contracts and realistic replay domains that test whether the atom interface transfers beyond the current controlled package.

References

- [1] Hengyu An, Jinghui Zhang, Tianyu Du, Chunyi Zhou, Qingming Li, Tao Lin, and Shouling Ji. Ipi-guard: A novel tool dependency graph-based defense against indirect prompt injection in llm agents. *arXiv preprint arXiv:2508.15310*, 2025.
- [2] Edoardo Debenedetti, Ilia Shumailov, Tianqi Fan, Jamie Hayes, Nicholas Carlini, Daniel Fabian, Christoph Kern, Chongyang Shi, Andreas Terzis, and Florian Tramer. Defeating prompt injections by design. *arXiv preprint arXiv:2503.18813*, 2025.
- [3] Edoardo Debenedetti, Jie Zhang, Mislav Balunovic, Luca Beurer-Kellner, Marc Fischer, and Florian Tramer. Agentdojo: A dynamic environment to evaluate prompt injection attacks and defenses for llm agents. *arXiv preprint arXiv:2406.13352*, 2024.
- [4] Yue Huang, Hang Hua, Yujun Zhou, Pengcheng Jing, Manish Nagireddy, Inkit Padhi, Greta Dolcetti, Zhangchen Xu, Subhajit Chaudhury, Ambrish Rawat, Liubov Nedoshivina, Pin-Yu Chen, Prasanna Sattigeri, and Xiangliang Zhang. Building a foundational guardrail for general agentic systems via synthetic data. *arXiv preprint arXiv:2510.09781*, 2025.
- [5] Yutao Mou, Zhangchi Xue, Lijun Li, Peiyang Liu, Shikun Zhang, Wei Ye, and Jing Shao. Toolsafe: Enhancing tool invocation safety of llm-based agents via proactive step-level guardrail and feedback. *arXiv preprint arXiv:2601.10156*, 2026.
- [6] Yangjun Ruan, Honghua Dong, Andrew Wang, Silviu Pitis, Yongchao Zhou, Jimmy Ba, Yann Dubois, Chris J. Maddison, and Tatsunori Hashimoto. Identifying the risks of lm agents with an lm-emulated sandbox. *arXiv preprint arXiv:2309.15817*, 2023.
- [7] Tianneng Shi, Jingxuan He, Zhun Wang, Linyu Wu, Hongwei Li, Wenbo Guo, and Dawn Song. Progent: Programmable privilege control for llm agents. *arXiv preprint arXiv:2504.11703*, 2025.
- [8] Jinhao Zhu, Kevin Tseng, Gil Vernik, Xiao Huang, Shishir G. Patil, Vivian Fang, and Raluca Ada Popa. Miniscope: A least privilege framework for authorizing tool calling agents. *arXiv preprint arXiv:2512.11147*, 2025.

A Additional Tables

B Audit Details

Leakage and label-hidden replay. The E55-v2 leakage audit reports `leakage_free=true` with no violations. E56 reports strict mode passed and label-hidden replay metrics equal for the original E55 contract. These checks support the claim that gold labels were not used as deployable inputs in the relevant evaluation path.

Reference authorizer. The E57-v2 reference authorizer is marked as an independent local implementation agreement check. It reports 600 rows, decision agreement 1.000, atom-count agreement 1.000, atom resource-set agreement 1.000, and no disagreements. Its claim scope is consistency checking, not independent deployment truth.

Table 7: Canonical E55 version policy used in this draft.

Artifact	Role in draft	Rationale
E55-v2 strict	Main pre-commit result	Corrected rerun with 600 rows, five domains, 0.880 authz-aware coverage, zero UPA, zero FDeny.
Original E55 strict	Sensitivity and ablation source	Provides original 0.920 coverage result and the ablation values 0.333, 0.148, 0.148, 0.211.
Original E55 human-corrected sensitivity	Audit/sensitivity evidence	Preserves zero UPA but introduces 0.017 FDeny after six decision corrections.
E57-v2 validity	Deterministic validity evidence	Resource perturbation and reference-authorizer checks on corrected v2.
E57 human audit	Human audit evidence	Reports 54/60 decision agreement and corrected-label subset; not merged with reference-authorizer agreement.

Table 8: E55-v2 versus original E55 ablation note. These values should not be mixed without labeling the source version.

Ablation metric	Original E55 strict	E55-v2 strict
No multi-resource expansion UPA	0.333	0.217
No operation-mode binding UPA	0.148	0.217
No provenance overlay UPA	0.148	0.217
No alias resolution FDeny	0.211	0.238

Resource perturbation. The E57-v2 resource-name perturbation keeps the authorization-aware guard’s UPA, coverage, decision accuracy, safe false-denial, and abstention unchanged. It reports changed decision count 0 and changed decision rate 0. This reduces the concern that the E55-v2 result depends only on memorized resource strings.

Human audit. The E57 human audit is a separate artifact. It reports 60 audited rows, 54/60 decision agreement, 46/60 all-checks-true, six decision corrections, thirteen atom corrections, and ten violation-reason corrections. The corrected cases primarily concern unknown-resource fallback and transaction-domain amount handling. The paper therefore uses corrected-label sensitivity wording.

C Reproduction Notes

Package root. The draft was built from:

```
/data/CSK/causal-agent-safety-research/
papermaterials/effect.binding.guard.paper/
mainline.tool.effect.binding.package
```

The package summary reports 2,424 copied files and no core-number issues.

Key source files. The main quantitative claims trace to:

- results/analysis/results/e48_tuple_guard_results.json
- results/analysis/results/e50_hard_guard_robustness_results.json
- audit/analysis/results/e55_v2_precommit_authz_results_strict.json
- results/analysis/results/e55_precommit_authz_results_strict.json
- results/analysis/results/e55_human_corrected_sensitivity.json
- audit/analysis/results/e56_final_report.json
- audit/analysis/results/e57_v2_validity_checks_report.json
- audit/analysis/results/e57_human_audit_validation.json

Table 9: Human audit correction summary.

Quantity	Value
Human-audited rows	60
Decision agreement	54/60 = 0.900
All human checks true	46/60 = 0.767
Decision corrections	6
Atom corrections	13
Violation-reason corrections	10

Targeted tests from package notes. The existing material check reports that the following targeted test command passed in the packaged source root:

```
cd code
PYTHONPATH=. python -m pytest
../tests/tests/test_effect.binding.guard.e55.precommit.authz.py
../tests/tests/test_effect.binding.guard.e57.validity.py -q
```

with result 22 passed. This draft did not rerun experiments; it restructures and writes from existing materials.

D Claim-to-Source Map

Table 10: Main claim-to-source map for the restructured draft.

Claim	Source artifact	Safe wording
The paper is measurement plus diagnostic framework plus local pre-commit prototype.	Claim boundary notes; planning log	Controlled custom-stress and local contract evidence, not production safety.
The hard guard has bounded improvement.	E48 tuple guard; E50 robustness	Low but nonzero UPA/FDeny on E48 and a resource/auth bottleneck on E50.
Resource/auth is the central bottleneck.	E50 robustness	0.617 UPA at 0.921 coverage on controlled resource/auth stress.
Authorization-aware mediation improves local contract decidability.	E55-v2 strict	On E55-v2, coverage rises from 0.200 to 0.880 and UPA falls from 12/276 to 0/276.
Human-corrected sensitivity preserves zero UPA but introduces FDeny.	E55 human-corrected sensitivity	Corrected sensitivity has UPA 0/320 and FDeny 4/230.
Validity checks reduce specific artifact risks.	E57-v2 validity; E57 human audit	Perturbation/reference-authorizer checks pass; human audit finds corrections.